

SGSI-UNCP

Política de Contraseñas y Autenticación Segura

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Política de Contraseñas y Autenticación Segura
 - 1.1 Objetivo
 - 1.2 Alcance
 - 1.3 Requisitos de Contraseñas
 - 1.4 Gestión de Credenciales
 - 1.5 Autenticación Multifactor (MFA)
 - 1.6 Bloqueo de Cuenta
 - 1.7 Autenticación para Acceso Remoto (Control A.8.5)
 - 1.8 Contraseñas Temporales y de Primer Acceso
 - 1.9 Responsabilidades
 - 1.10 Métricas de Cumplimiento
 - 1.11 Documentos Relacionados

1. Política de Contraseñas y Autenticación Segura

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Oficial de Seguridad y Confianza Digital **Norma:** ISO/IEC 27001:2022 (Controles A.5.17, A.8.3, A.8.5) **Referencia Técnica:** NIST SP 800-63B (Digital Identity Guidelines) **Alineamiento:** P-SGSI-03 (Gestión de Accesos), POL-SGSI-05 (Dispositivos Móviles)

1.1. Objetivo

Establecer los requisitos mínimos de creación, uso, almacenamiento y rotación de contraseñas en la UNCP, así como las condiciones para el uso de mecanismos de autenticación multifactor, con el fin de reducir el riesgo de accesos no autorizados a los sistemas institucionales.

1.2. Alcance

Esta política aplica a todo usuario de los sistemas de información de la UNCP (personal administrativo, docente, estudiantes, contratistas y proveedores) que utilice credenciales de acceso para autenticarse en recursos institucionales.

1.3. Requisitos de Contraseñas

1.3.1. 3.1 Creación y Complejidad

Parámetro	Requisito Mínimo
Longitud mínima	12 caracteres (se recomienda 14+)
Longitud máxima	No debe imponerse límite corto; se aceptan hasta 128 caracteres
Composición	No se exige composición forzada (mayúscula, minúscula, número, símbolo) según NIST SP 800-63B. Sin embargo, se recomienda incluir al menos 3 de las 4 categorías
Caracteres permitidos	Todos los caracteres ASCII imprimibles, incluyendo espacio
Verificación contra listas negras	La contraseña NO debe estar en listas de contraseñas comunes comprometidas (Have I Been Pwned, listas RockYou, etc.)
Similitud con datos personales	No debe contener el nombre de usuario, nombre real, DNI, fecha de nacimiento, o datos institucionales fácilmente adivinables

1.3.2. 3.2 Lista Negra de Contraseñas (Prohibidas)

El sistema de autenticación debe rechazar automáticamente las siguientes contraseñas (evaluadas por el IdM o política de directorio activo): - Contraseñas comunes: 123456, password, admin, admin123, uncp123, universidad, 123456789, etc. - Variantes del nombre de la institución: UNCP2026, univcentro, uncp_admin. - Secuencias de teclado: qwerty, asdfgh, zxcvbn. - Repeticiones: aaaaaaaa, 12341234. - Cualquier contraseña encontrada en violaciones de datos públicas (Have I Been Pwned).

1.3.3. 3.3 Almacenamiento y Transmisión

- Las contraseñas **nunca** deben almacenarse en texto plano. Deben almacenarse utilizando funciones de hash criptográfico con sal (bcrypt, Argon2id, PBKDF2 o similar).
- Las contraseñas deben transmitirse exclusivamente por canales cifrados (HTTPS/TLS, VPN).

- Queda prohibido que los sistemas muestren la contraseña en claro en ningún momento (pantalla, correo, logs).

1.3.4. 3.4 Rotación de Contraseñas

- **No se exige** cambio periódico de contraseña para usuarios estándar, salvo que exista sospecha de compromiso (NIST SP 800-63B desaconseja el cambio forzado periódico).
- **Cambio obligatorio** solo en los siguientes casos:
 - Sospecha o confirmación de compromiso de la cuenta.
 - Después de la recuperación de una cuenta comprometida.
 - Al reasignar una cuenta a otro usuario.
 - Cambio forzado en la primera autenticación (contraseña temporal).
- Para **cuentas privilegiadas** (administradores OTI, DBA, administradores cloud): rotación cada 90 días.

1.3.5. 3.5 Historial

- No se permite repetir las últimas 5 contraseñas utilizadas.
-

1.4. Gestión de Credenciales

1.4.1. 4.1 Prohibiciones

- Las credenciales de acceso son **personales e intransferibles**. Queda prohibido compartir contraseñas con otros usuarios, incluyendo compañeros de trabajo o superiores jerárquicos.
- Queda prohibido escribir contraseñas en notas adhesivas visibles, debajo del teclado, o en cualquier lugar accesible por terceros.
- Queda prohibido almacenar contraseñas en archivos de texto plano, hojas de cálculo, correos electrónicos o documentos sin cifrar.

1.4.2. 4.2 Uso de Gestores de Contraseñas

La UNCP permite y **recomienda el uso de gestores de contraseñas empresariales** para el personal administrativo y técnico. El gestor institucional sugerido debe: - Estar aprobado por la OTI. - Exigir una contraseña maestra robusta (mínimo 14 caracteres, no reutilizada en ningún otro servicio). - Tener habilitada la autenticación multifactor para acceder al cofre de contraseñas. - Permitir el uso compartido seguro de credenciales entre miembros del equipo (para cuentas de servicio o compartidas).

1.4.3. 4.3 Cuentas de Servicio y Compartidas

- Las cuentas de servicio (no personales) deben tener contraseñas generadas aleatoriamente de al menos **20 caracteres**.
 - Las contraseñas de cuentas de servicio deben rotarse cada **180 días**.
 - Las cuentas compartidas (ej. `soporte@uncp.edu.pe`) deben estar asociadas a un grupo de usuarios nominativos. El acceso a la contraseña debe gestionarse a través del gestor de contraseñas empresarial.
-

1.5. Autenticación Multifactor (MFA)

1.5.1. 5.1 Obligatoriedad

Tipo de Usuario	MFA Exigido	Método Principal
Administrativo con acceso a sistemas críticos	Obligatorio	App de autenticación (Microsoft Authenticator, Google Authenticator)
Docente (acceso a notas, actas, VPN)	Obligatorio	App de autenticación
Administradores de sistemas (OTI)	Obligatorio	Llavero FIDO2 / Token físico + app de respaldo
Estudiante (acceso a Moodle, correo)	Recomendado	App de autenticación o SMS
Contratista / Proveedor	Obligatorio	App de autenticación

1.5.2. 5.2 Excepciones al MFA

Solo se permite el acceso sin MFA en los siguientes casos, con autorización del Oficial de Seguridad: - Cuentas de servicio que no permiten MFA técnicamente, con controles compensatorios (IP restringida, certificado de cliente). - Sistemas legacy sin soporte de MFA, con plan de migración documentado. - Excepción temporal (máximo 30 días) por pérdida del dispositivo de autenticación.

1.6. Bloqueo de Cuenta

Parámetro	Valor
Umbral de bloqueo	5 intentos fallidos consecutivos
Duración del bloqueo	30 minutos automáticos, o hasta que el administrador desbloquee manualmente
Notificación	Al superar el umbral, se envía una notificación al usuario y al equipo de seguridad
Cuentas privilegiadas	El umbral se reduce a 3 intentos fallidos. El desbloqueo solo puede realizarse manualmente por el administrador del sistema

1.7. Autenticación para Acceso Remoto (Control A.8.5)

Todo acceso remoto a los sistemas de la UNCP (VPN, escritorio remoto, consolas de administración cloud) debe cumplir: - MFA obligatorio. - Sesión con tiempo de expiración por inactividad: máximo **15 minutos**. - Conexión cifrada (TLS 1.2+, IPsec). - Las cuentas de acceso remoto deben ser nominativas. No se permiten cuentas genéricas para acceso remoto.

1.8. Contraseñas Temporales y de Primer Acceso

- Las contraseñas temporales (otorgadas en la creación de la cuenta o después de un restablecimiento) deben:
 - Ser generadas aleatoriamente (mínimo 12 caracteres).
 - Expirar en un máximo de **24 horas** o en el **primer inicio de sesión exitoso**.
 - Forzar el cambio de contraseña en el primer inicio de sesión.
- No se deben enviar contraseñas temporales por canales no seguros. Preferir el envío a través del portal de autoseguro o entrega presencial.

1.9. Responsabilidades

Rol	Responsabilidad
Usuario	Crear contraseñas seguras; no compartir credenciales; usar MFA; reportar cualquier sospecha de compromiso.
OTI (Soporte)	Configurar y mantener las políticas de contraseñas en el IdM/Directorio Activo; gestionar el restablecimiento de contraseñas.
OTI (Seguridad)	Mantener la lista negra de contraseñas; auditar la fortaleza de las contraseñas periódicamente; gestionar el MFA.
Oficial de Seguridad	Definir y mantener esta política; autorizar excepciones; revisar el cumplimiento.

1.10. Métricas de Cumplimiento

Indicador	Meta	Frecuencia	Fuente
% de usuarios con MFA activado (personal)	100 %	Mensual	IdM / Directorio Activo
% de cuentas con contraseñas en lista negra	0 %	Trimestral	Auditoría de hash de contraseñas
Tiempo medio de desbloqueo de cuenta	< 1 hora	Mensual	Sistema de tickets
Número de intentos de autenticación fallidos	Reporte mensual	Mensual	SIEM
% de cuentas de servicio con rotación < 180 días	100 %	Trimestral	Sistema PAM

1.11. Documentos Relacionados

Código	Nombre
P-SGSI-03	Gestión de Identidades y Control de Acceso
POL-SGSI-02	Política de Uso Aceptable, Escritorio y Teletrabajo
POL-SGSI-05	Política de Seguridad para Dispositivos Móviles del Personal
D-SGSI-08	Guía de Implementación de Controles (ISO 27002)

__**